Security Testing for SQA Engineers

Modern Security Testing talk for SQA Professionals

WHO AM I

MD AMAN BHUIYAN

Security Engineer

A part time Bug Hunter x Independent Security Researcher

GLOBAL RECOGNITION

Global Recognition & Hall of Fame Honored by NASA, Google, Adobe, Ferrari, and Sony for vulnerability findings (50+ reports)

https://www.linkedin.com/in/bhuiyanaman71/

SQA Checklists (Soft Reminder)

Secure Coding Guidelines

Secure Coding Guideline : For software development team to have a head start on creating secure software with this guide. Adding more items that match our specific business requirements.

1. Validate ALL types of input.
2.Encoding output is required.
3.Parameterized queries are required, dynamic SQL is forbidden.
4.Use Authorization and Authentication in your framework, do not write your own.
5.Use the identity and session management features in your framework, network, or cloud.
6.All applicable security headers should be used.
7.Do not cache sensitive page data.
8.Sensitive data should be stored in secure cookies, and all available security features used.
9.Take every possible precaution when performing file uploads.
10. All errors should be caught, handled, logged, and, if appropriate, alerted upon.
11. Sensitive data should never be put in URL parameters
12. Your application should be served over HTTPS only.
13. All data must be encrypted in transit and at rest, use the latest version of TLS.
14. Allow users to cut and paste into the password field, for password managers.
15. All connection strings, hashes, passwords and other secrets must be kept in a secret store.
16. Hash and salt all passwords. Make the salt at least 28 characters.
17. Keep your programming framework(s) and dependencies up to date.

Notion

Secure Coding Guidelines | Notion

Secure Coding Guideline : For software development team to have a head start on creating secure software with this guide. Adding more items that match our specific business requirements.

easabbir on Notion

Prince-71-Cloud/
ChecklistForSQA-DEV

Your go-to checklist for software development and QA — covering everything from building applications to testing new features end-to-end.

1 Contributor | 0 Issues | 0 Stars | 0 Forks

ChecklistForSQA-DEV/CheckList_for_InputValidation.md at main · Prince-71-Cloud/ChecklistForSQA-DEV

Your go-to checklist for software development and QA — covering everything from building applications to testing new features end-to-end. - Prince-71-Cloud/ChecklistForSQA-DEV

GitHub

- https://easabbir.notion.site/Secure-Coding-Guidelines-35e4127e2fb480a3907adcc807b3c9fe
- https://github.com/Prince-71-Cloud/ChecklistForSQA-DEV/blob/main/CheckList_for_InputValidation.md

Why Security Matters

Account Takeover via Password Reset without user interactions

Report

SUMMARY BY GITLAB

@asterion04 submitted a report to GitLab.

Summary

I found a way to change the password of a GitLab account via the password reset form and successfully retrieve the final reset link without user interactions, using just its email address.
Steps to reproduce

Go to "Forgot Your Password?" link
Enter the victim's email and intercept the submit request via Burp Suite .
Then right-click on the HTTP Editor inside Burp Suite and select Extensions -> Content-Type Converter -> Convert to JSON (make sure to have the Content-Type Converter plugin installed from the BApp Store)
Now replace this converted JSON line `"user[email]":"victim@gmail.com"`, to

Code · 106 Bytes

```
"user" {
    "email" [
            "victim@gmail.com",
            "attacker@gmail.com"
        ]
},
```

Forward the requests and you should get an email containing the reset link that was send to both emails (`victim@gmail.com` and `attacker@gmail.com`).
Click on the reset link, change the password and done, you can now login as the victim using the new password.

Impact

By just knowing the victim email address used on GitLab, you can takeover his account by changing his password without user interaction since the attacker get the same email as the victim.

Reported on
December 20, 2023, 6:41pm UTC

Reported by
asterion04

Reported to
GitLab Managed

Participants

Report Id
#2293343 Resolved

Severity
Critical (10.0)

Disclosed
February 26, 2025, 6:29am UTC

Weakness
Improper Access Control - Generic

CVE ID
None

Bounty
$35,000

Retest
None

Total reward
None

Account details

Source: https://hackerone.com/reports/2293343

Why Security Matters

Payload delivery via Social Media URLs

tedix submitted a report to HackerOne. April 29, 2024, 8:49pm UTC

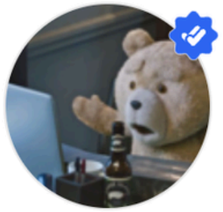
Summary:

HackerOne allows users to add social media profiles to their HackerOne profile via the profile/edit page. Users are allowed to provide their username. Due to improper sanitization, users are allowed to construct their own URLs (except Twitter, which is sanitized and shows inconsistency in security controls). This allows hackers to hide malicious payloads behind the social media buttons on their profile, such as malicious .zip files.

GitHub handle

Tedixx/i/raw/i/i.zip

https://github.com/tedixx/i/raw/i/i.zip



(tedix)

Sr. Security consultant - Microsoft Most Valuable Researcher 2021-2022 - NCSC Wall of Fame 2022, 2023

Follow

Europe

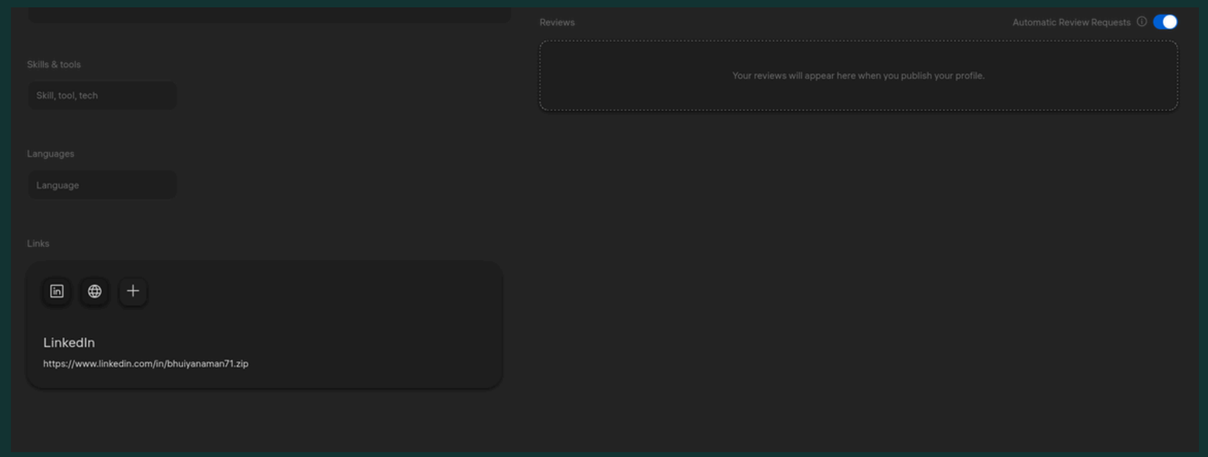
Joined September 2017

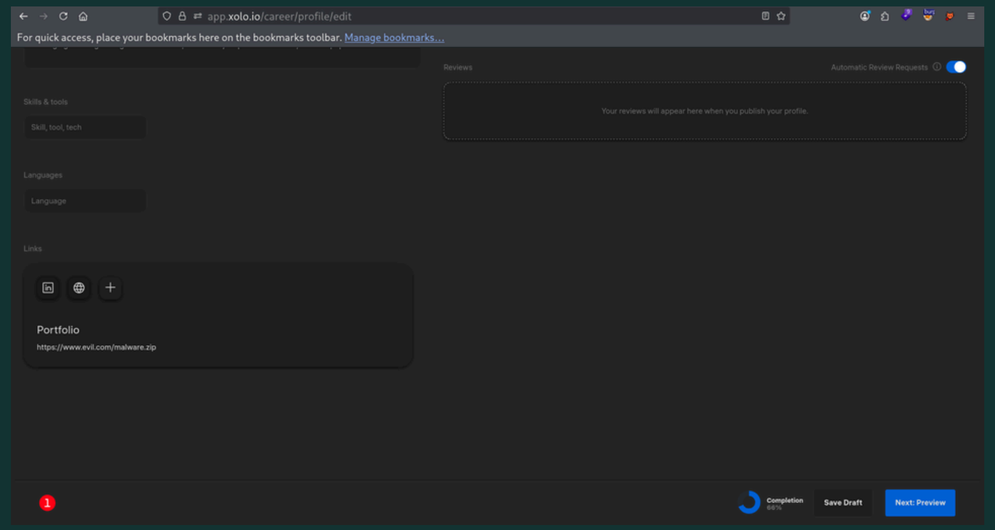
Payload

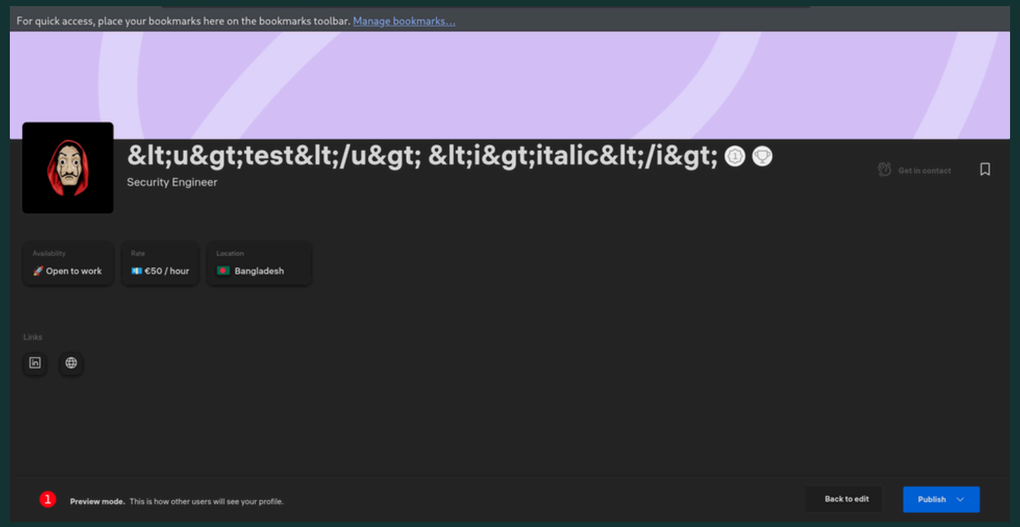
Source: https://hackerone.com/reports/2483422

Why ~~Security~~ Matters

Malware delivery via Social Media URLs







https://medium.com/@icecream23/when-a-trusted-profile-link-becomes-a-malware-delivery-vector-30dac8d85afc

What We're Breaking

01 From Functional QA to Security QA

02 The "Rulebook of Legends" (OWASP)

03 Web Hygiene

04 Injection Testing

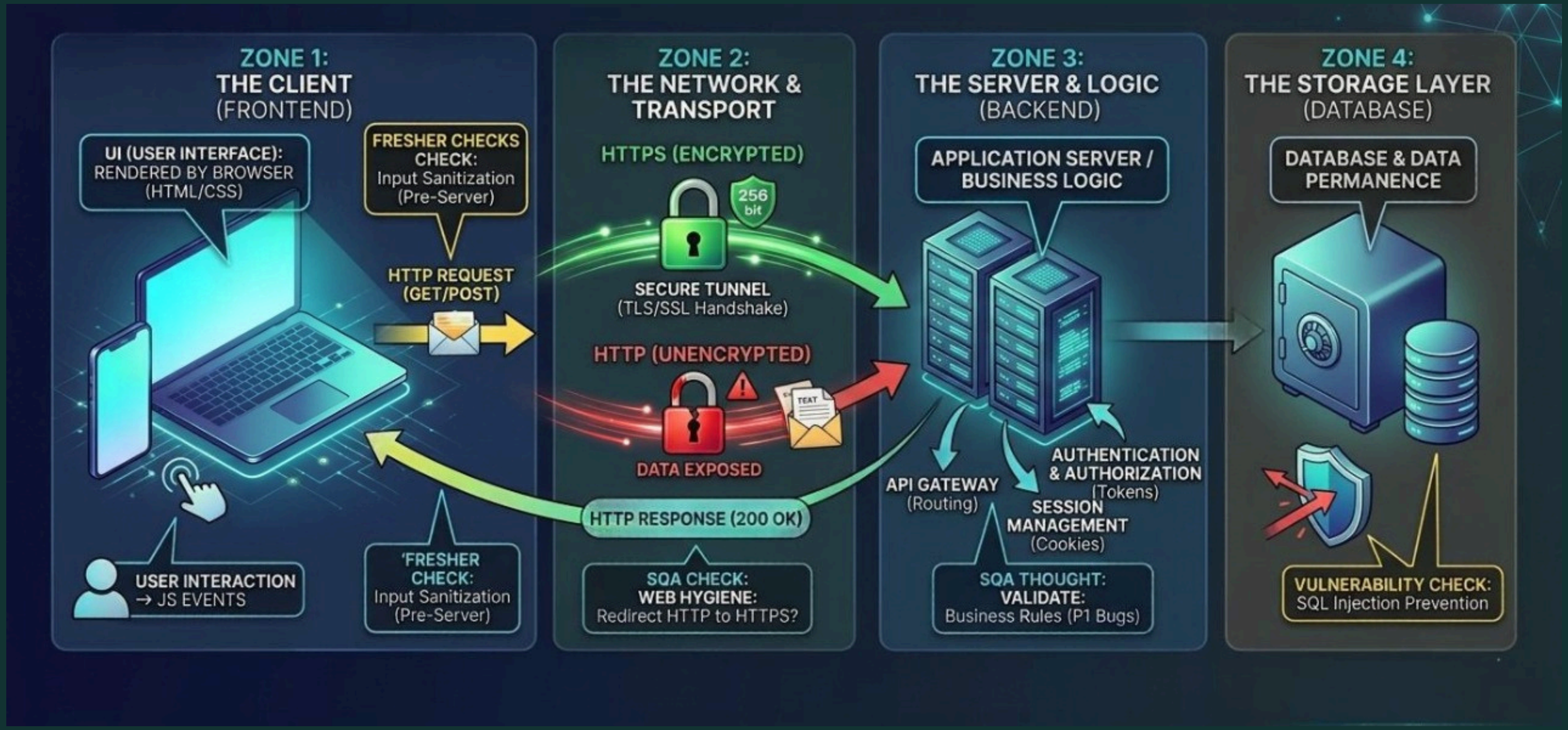
05 API Security

06 Business Logic Bugs

07 The SQA Security Toolkit

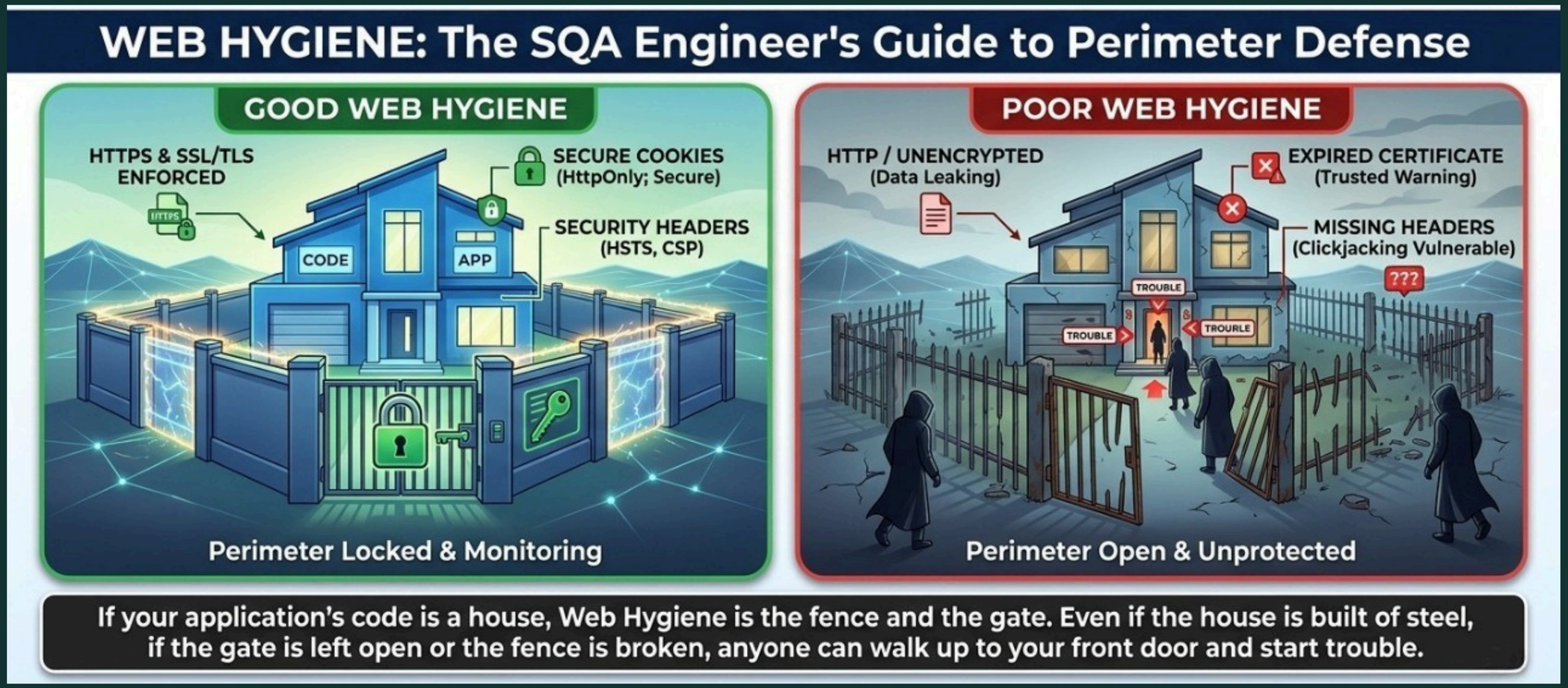
08 Security tips

How Wep Application Works

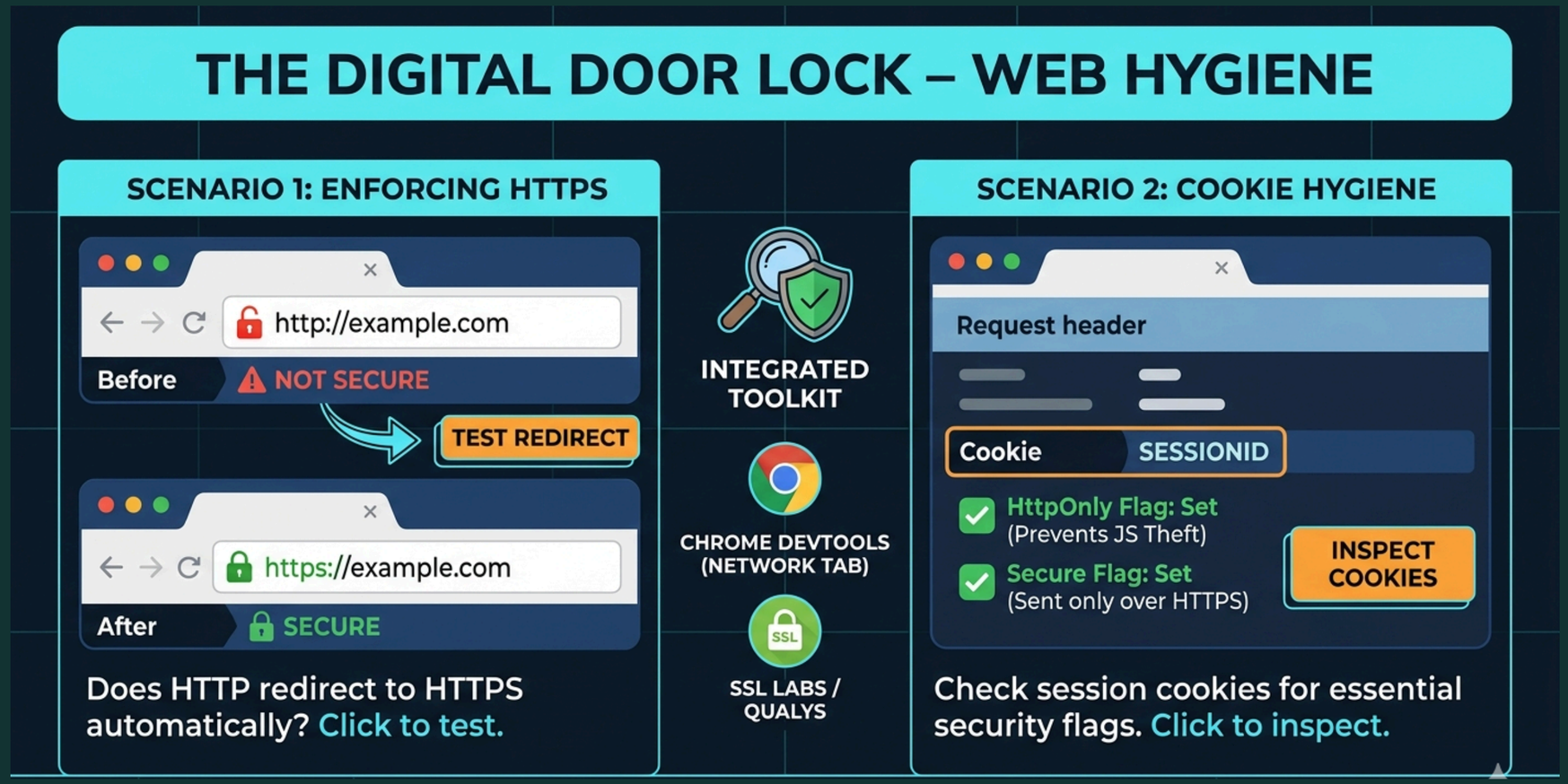


Web Hygiene

- The practice of maintaining a clean, secure, and encrypted communication channel between the user's browser and the web server by correctly configuring transport protocols and security headers.



Web Hygiene



Important Topics

- HttpOnly Flag
- CSP: Content Security Policy
- HSTS: HTTP Strict Transport Security
- HTTP Headers
- JSON Body

- HTTPS Enforcement: Does the site automatically redirect http:// to https://?
- SSL/TLS Certificate Sanity: Is the certificate expired? Does it show the "Green Padlock" or a "Not Secure" warning?
- Cookie Hygiene: Ensuring the cookie is never sent over an unencrypted connection.

The "Rulebook of Legends" (OWASP) 📖

- The Cheat Codes used by professional security testers worldwide to find the most common bugs.

🌐 https://owasp.org/

The OWASP Top 10 is a standard awareness document for developers and web application security. It represents a broad consensus about the most critical security risks to web applications.

The "Rulebook of Legends" (OWASP) 📖

What Every SQA Engineer Must Know

01 Input Validations 💉

02 The Unlimited Money Glitch (Business Logic) 💰

03 Your Batman (Tools) 🛠️

04 Security Bug Reporting 📝

Input Validations

The process of ensuring that a program operates on clean, correct, and useful data.

SQA Perspective: It’s the "Gatekeeper." If the gate is open, anything (malicious scripts, massive files, wrong data types) can get in.

Why Should an SQA Care?

Checklist

01 Data Type: Can I put letters in a phone number field ?

02 Length: What happens if I paste a 10,000-word essay into the "Username" box ?

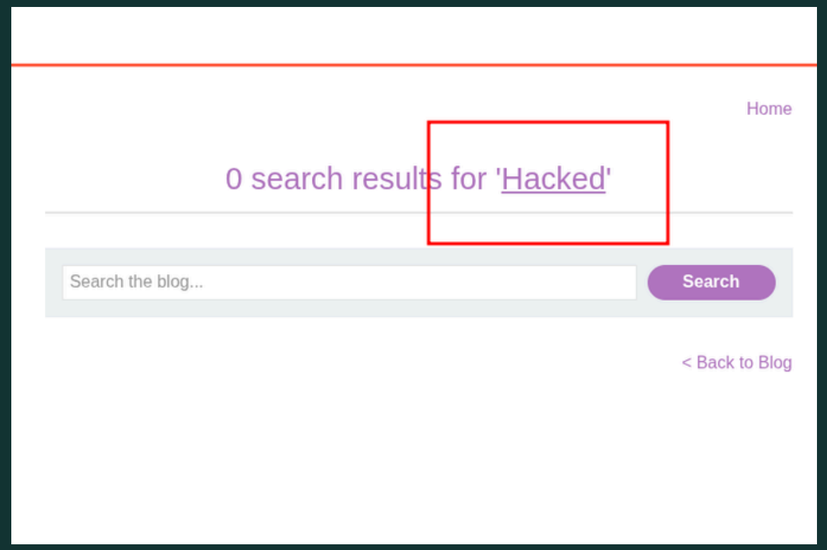
03 Special Characters: Testing for symbols like ', ", <, >, ;, and &

04 Range: Can I set my age to -1 or 999 ?

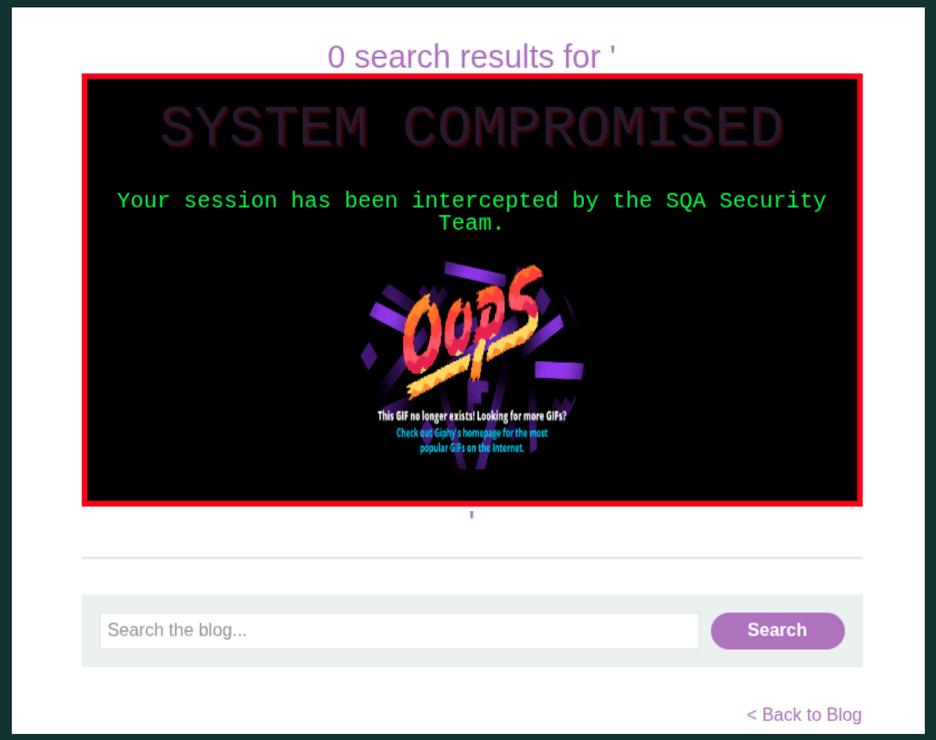
06 Does the email field accept not_an_email@@.com ?

Injections Testing

Html Injection: HTML Injection is a vulnerability where an attacker inputs malicious HTML code into a web application, causing the browser to render unauthorized content or alter the page's appearance for other users.



<u>Hacked</u>



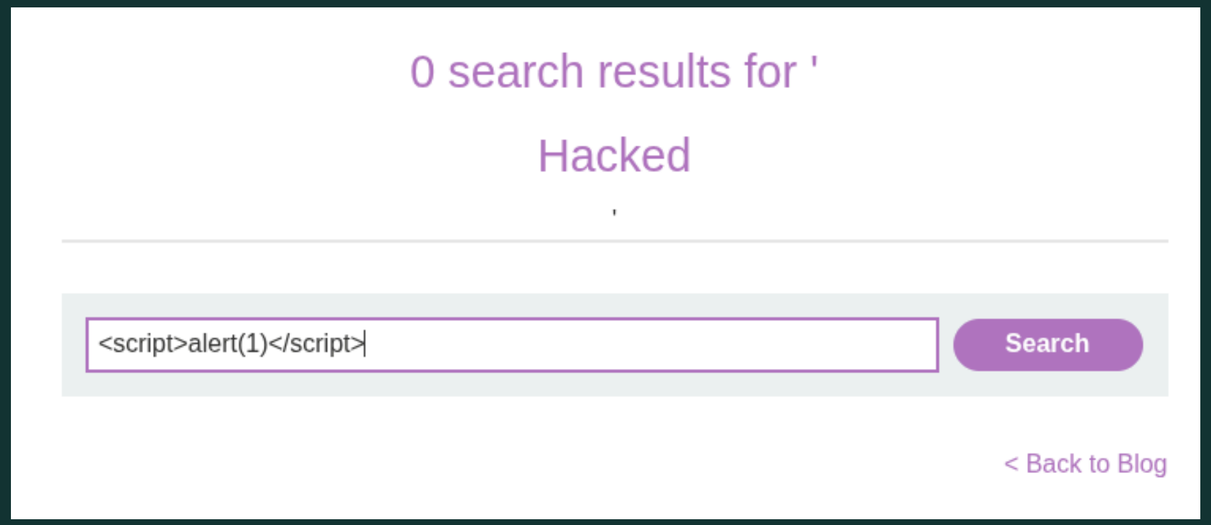
 <h1 style="text-shadow: 2px 2px #FF0000; animation: blink 1s infinite;"> SYSTEM COMPROMISED </h1> Your session has been intercepted by the SQA Security Team. <iframe src="https://giphy.com/embed/V4NSRTsA6oVN23RxlY" width="200" height="200" frameBorder="0" style="border-radius: 50%;"></iframe> <style> @keyframes blink { 0% {opacity: 1;} 50% {opacity: 0.2;} 100% {opacity: 1;} } </style>

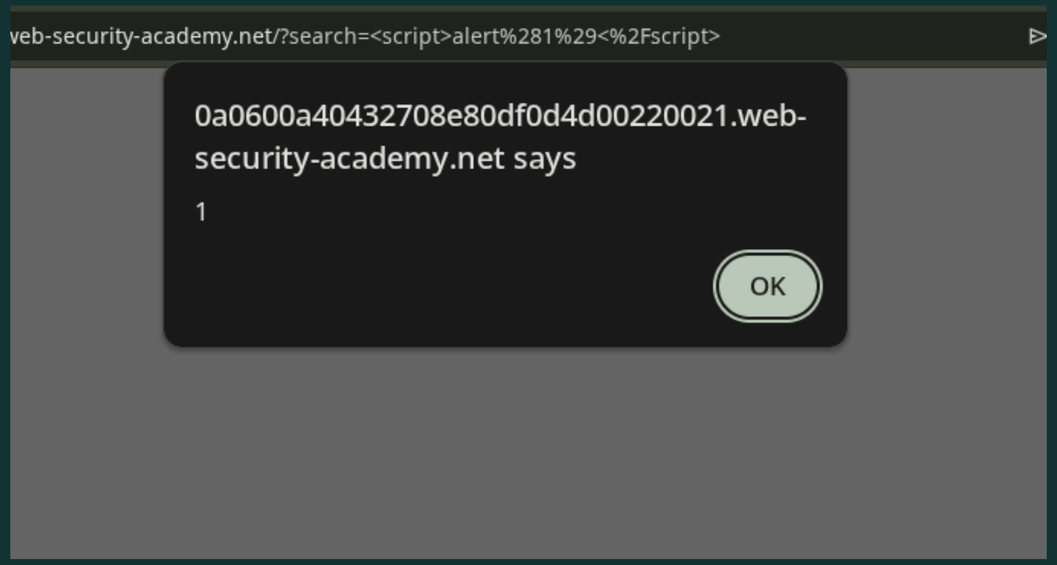
Practical Lab

https://portswigger.net/web-security/cross-site-scripting/reflected/lab-html-context-nothing-encoded

Injections Testing

XSS Attack: HTML Injection is a vulnerability where an attacker inputs malicious HTML code into a web application, causing the browser to render unauthorized content or alter the page's appearance for other users.





<script>alert(1)</script>

Practical Lab

https://portswigger.net/web-security/cross-site-scripting/reflected/lab-html-context-nothing-encoded

Always Remember That

THE SQA'S GUIDE TO API SECURITY

SQA KEYWORD	WHAT IT MEANS IN PLAIN ENGLISH
Authentication	🔑 **"Who are you?"** (Checking the API Key or Token).
Authorization	✅ **"What are you allowed to do?"** (Can a Customer delete an Admin?).
Data Exposure	🕵️ **"Are you telling too much?"** (Does the API send the password in the JSON response?).
Rate Limiting	🛑 **"Slow down!"** (Preventing a script from calling the API 1,000 times a second).

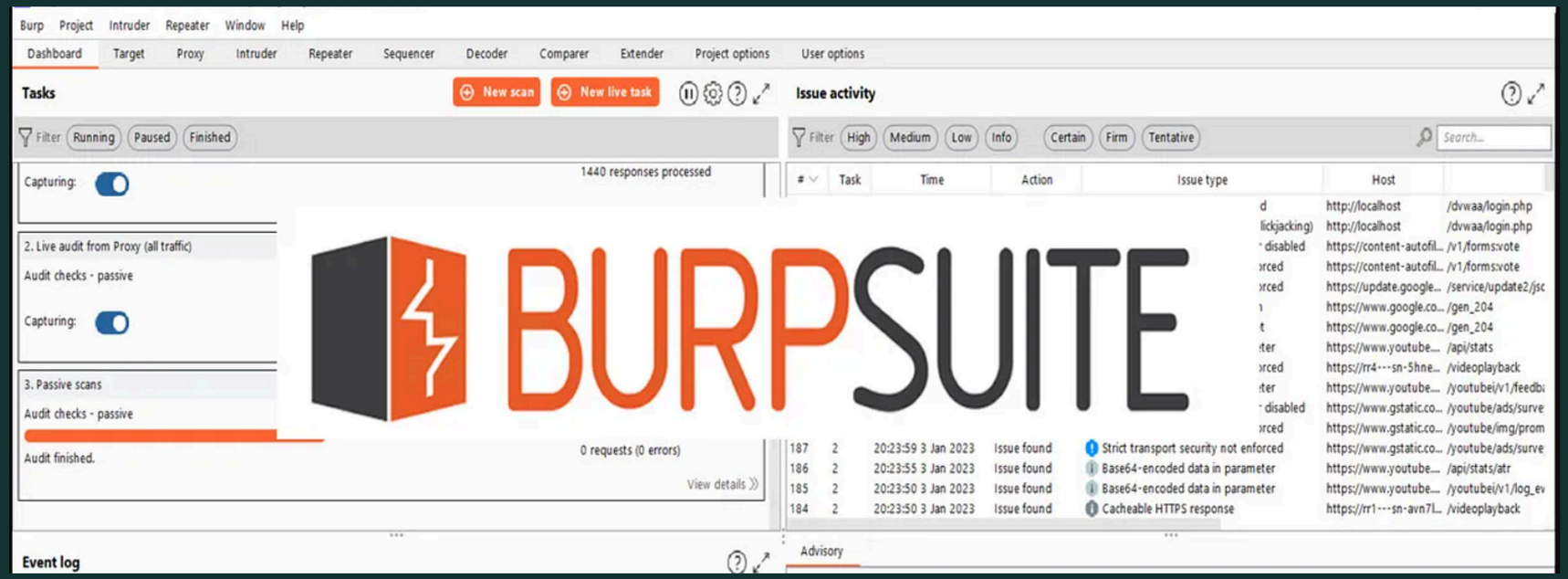
Business Logic Bugs

A Business Logic Bug is a security flaw that occurs when an application's legitimate features are used in an unintended way to achieve a malicious goal. It exploits design flaws in the rules and workflows of the business.

Scenario	The "Logic" Fail
E-Commerce	Can I add a item to my cart and change the price to $0.01 in the request?
Coupon Codes	Can I apply a 100% discount code multiple times to get a negative total?
Voting Systems	Can I vote for the same person 1,000 times by bypassing the "one-click" rule?
Subscription	Can I access "Premium" features by manually changing isPaid=false to isPaid=true in the browser?

Business logic bugs aren't about 'broken code'; they are about 'broken common sense.

The SQA Security Toolkit 🛠️



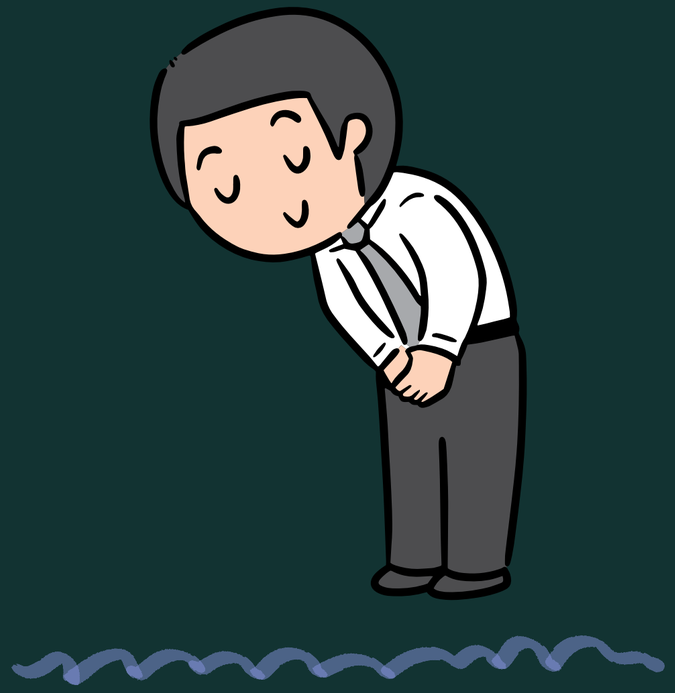
Mastering Burp Suite: The Industry Standard for Finding, Intercepting, and Neutralizing Web Vulnerabilities.

QUESTIONS ?

Challenge !!!

The original photographer of this picture commented the flag on his post. Find the flag.

[csictf{flag}]



Thank You